

OWASP TOP 10 WEB APPLICATION SECURITY RISKS (2021)

Introduction

The Open Worldwide Application Security Project (OWASP) is a nonprofit organization dedicated to improving software security. One of its most recognized publications is the **OWASP Top 10**, which identifies the most critical security risks affecting web applications. The OWASP Top 10 serves as a standard awareness document for developers, security professionals, and organizations worldwide. It helps organizations understand common vulnerabilities and implement effective security measures to protect applications and sensitive data. ([OWASP Foundation](#))

A01:2021 – Broken Access Control

Description

Broken Access Control occurs when users can perform actions or access resources beyond their intended permissions. Access controls are designed to enforce restrictions so that users can only access information and functions authorized for them.

When access controls fail, attackers may gain unauthorized access to sensitive data, administrative functions, or other users' accounts. This vulnerability ranked as the number one risk in the OWASP Top 10 2021 list. ([OWASP Foundation](#))

Examples

- Viewing another user's account by modifying a URL.
- Accessing admin pages without authorization.
- Changing account permissions without proper rights.
- Performing actions as another user.

Impact

- Unauthorized access to sensitive information.

- Data theft and manipulation.
- Privilege escalation.
- Complete system compromise.

Mitigation

- Implement role-based access control (RBAC).
 - Enforce least privilege principles.
 - Validate permissions on every request.
 - Deny access by default.
 - Regularly review access permissions.
-

A02:2021 – Cryptographic Failures

Description

Cryptographic Failures occur when sensitive information is not adequately protected through encryption. This category was previously known as "Sensitive Data Exposure" and focuses on failures related to cryptography and data protection. ([OWASP Foundation](#))

Examples

- Storing passwords in plain text.
- Using weak encryption algorithms.
- Transmitting sensitive data without HTTPS.
- Poor key management practices.

Impact

- Identity theft.
- Financial fraud.
- Exposure of confidential information.
- Regulatory compliance violations.

Mitigation

- Use strong encryption algorithms.
- Encrypt sensitive data both at rest and in transit.
- Implement HTTPS everywhere.
- Securely manage encryption keys.

A03:2021 – Injection

Description

Injection vulnerabilities occur when untrusted input is interpreted as commands or queries by an interpreter. Common examples include SQL Injection, NoSQL Injection, Command Injection, and LDAP Injection. Cross-Site Scripting (XSS) is also included in this category in OWASP Top 10 2021. ([OWASP Foundation](#))

Examples

- SQL Injection.
- Command Injection.
- LDAP Injection.
- Cross-Site Scripting (XSS).

Impact

- Unauthorized database access.
- Data modification or deletion.
- Remote code execution.
- System takeover.

Mitigation

- Use parameterized queries.
- Validate and sanitize user input.
- Apply input allow-listing.
- Use ORM frameworks securely.

A04:2021 – Insecure Design

Description

Insecure Design is a new category introduced in OWASP Top 10 2021. It focuses on security weaknesses arising from poor application design rather than implementation flaws. Applications lacking proper threat modeling and security controls often fall into this category. ([OWASP Foundation](#))

Examples

- Missing security requirements.
- Lack of threat modeling.
- Weak business logic controls.
- Inadequate security architecture.

Impact

- Security weaknesses embedded into the system.
- Increased attack surface.
- High remediation costs.

Mitigation

- Perform threat modeling.
- Follow secure design principles.
- Conduct security reviews during design.
- Implement security requirements early.

A05:2021 – Security Misconfiguration

Description

Security Misconfiguration occurs when applications, servers, databases, or cloud environments are configured insecurely. It is one of the most common causes of application vulnerabilities. ([OWASP Foundation](#))

Examples

- Default passwords.
- Unnecessary services enabled.
- Improper cloud permissions.
- Detailed error messages exposed to users.

Impact

- Unauthorized access.
- Information leakage.

- Increased attack opportunities.

Mitigation

- Remove default configurations.
 - Disable unnecessary features.
 - Harden servers and applications.
 - Perform regular security reviews.
-

A06:2021 – Vulnerable and Outdated Components

Description

This vulnerability occurs when organizations use software libraries, frameworks, or components that contain known security vulnerabilities. Attackers often exploit publicly disclosed weaknesses in outdated software. ([OWASP Foundation](#))

Examples

- Using outdated frameworks.
- Running unsupported software versions.
- Missing security patches.

Impact

- Remote code execution.
- Data breaches.
- Full application compromise.

Mitigation

- Maintain software inventories.
 - Regularly update dependencies.
 - Monitor security advisories.
 - Remove unused components.
-

A07:2021 – Identification and Authentication Failures

Description

Previously known as Broken Authentication, this category includes vulnerabilities related to user identity verification and session management failures. Attackers exploit these weaknesses to compromise user accounts. ([OWASP Foundation](#))

Examples

- Weak password policies.
- Session fixation attacks.
- Credential stuffing.
- Predictable session tokens.

Impact

- Account takeover.
- Identity theft.
- Unauthorized access.

Mitigation

- Implement Multi-Factor Authentication (MFA).
- Enforce strong password policies.
- Use secure session management.
- Monitor suspicious login activities.

A08:2021 – Software and Data Integrity Failures

Description

This category addresses failures related to software updates, CI/CD pipelines, third-party libraries, and data integrity verification. It was introduced as a new category in OWASP Top 10 2021. ([OWASP Foundation](#))

Examples

- Unverified software updates.
- Insecure CI/CD pipelines.
- Trusting unverified plugins.
- Unsafe deserialization.

Impact

- Malicious code execution.
- Supply chain attacks.
- System compromise.

Mitigation

- Verify software integrity.
- Secure CI/CD pipelines.
- Digitally sign software updates.
- Validate external dependencies.

A09:2021 – Security Logging and Monitoring Failures

Description

Organizations often fail to properly log, monitor, and respond to security events. Without adequate logging, attackers can remain undetected for extended periods. ([OWASP Foundation](#))

Examples

- Missing audit logs.
- Insufficient monitoring.
- Failure to detect attacks.
- Lack of incident response procedures.

Impact

- Delayed breach detection.
- Increased attack duration.

- Difficulty performing forensic investigations.

Mitigation

- Enable comprehensive logging.
 - Implement centralized monitoring.
 - Configure alerts for suspicious activities.
 - Develop incident response plans.
-

A10:2021 – Server-Side Request Forgery (SSRF)

Description

Server-Side Request Forgery (SSRF) occurs when an application fetches remote resources without properly validating user-supplied URLs. Attackers can manipulate requests to access internal systems or sensitive services. SSRF was introduced as a new category in OWASP Top 10 2021. ([OWASP Foundation](#))

Examples

- Accessing internal APIs.
- Reading cloud metadata services.
- Scanning internal networks.

Impact

- Internal network exposure.
- Data theft.
- Cloud environment compromise.

Mitigation

- Validate and sanitize URLs.
 - Restrict outbound network access.
 - Use allow-listed destinations.
 - Disable unnecessary protocols.
-

Importance of OWASP Top 10

The OWASP Top 10 is widely recognized as the industry standard for web application security awareness. Organizations use it to:

- Identify common security risks.
- Improve secure coding practices.
- Train developers and security teams.
- Conduct security assessments.
- Strengthen application security programs.

Following OWASP recommendations significantly reduces the likelihood of successful cyberattacks and helps organizations build more secure applications. ([OWASP Foundation](#))

Conclusion

The OWASP Top 10 (2021) highlights the most critical web application security risks faced by organizations worldwide. These vulnerabilities range from Broken Access Control and Injection attacks to Security Misconfiguration and Server-Side Request Forgery. Understanding these risks and implementing the recommended mitigation strategies is essential for developing secure applications and protecting sensitive information from cyber threats. By following OWASP guidelines, organizations can strengthen their security posture and reduce the likelihood of successful attacks. ([OWASP Foundation](#))

References

- OWASP Top 10 2021 Documentation
- OWASP Foundation
- OWASP Top Ten Project
- Application Security Best Practices
- OWASP Security Awareness Resources ([OWASP Foundation](#))